

The Edge of the Attack Surface
Attack Vectors & Techniques

Alex MacIntyre

Introduction: *The Edge of the Attack Surface*

As observed by author *Kobo Abe*, the first tools that humans learned to use were the stick and the rope.

[1] The stick to ward off enemies, and to defend. The rope to pull towards, offer support, and extend help. Neither holds an instinctively good or evil purpose. Questions of morality are not concerning tools themselves, but the hand that wields them, and the intent that raised that hand. The intended purpose of a tool may be positive, convenient, or even revolutionary. However, the same human ingenuity that created the tools for an intended purpose is the exact same ingenuity that can use it for another. Often, when we see a useful tool, its intended purpose feels implicit and streamlined. A hammer is a stick with a flat metal end, angled just right to swing into a positioned nail. That same tool, to a resourceful mind, can prop open doors, flatten a dent, and more. A malicious mind may use it as a part of their break-and-enter toolkit, or perhaps a weapon. The hammer companies need not worry about every possible misuse, but instead focus on “hammering home” its core intended purpose by simply making a good hammer. When the instructions for the hammer are left behind, and it is used to harm, the action and method behind that causes the harm is considered an attack vector.

This report examines three such attack vectors, through emerging and obscure modern technology that can be demonstrated with brand new hardware:

Vector 1: Acoustic Cryptanalysis via High Frequency Emissions

Vector 2: Session Key Extraction from Unprotected Flash Memory on LoRaWAN Sensors

Vector 3: IoT Intrusion Detection Machine Learning Data Poisoning

Each vector is a deliberate repurposing of a neutral tool, and understanding their function, the methods behind them, and how to mitigate harm, is an important move for ensuring the safety and stability of the tools we use every day.

Vector 1: *Acoustic Cryptanalysis via High Frequency Emissions*

Electronic components such as CPUs, capacitors, and voltage regulators vibrate differently depending on what they are computing. Multiplication vs. Addition. “Does the text match, or not?” Each creates a unique acoustic signature. Acoustic cryptanalysis recovers cryptographic keys by recording the high-frequency sounds a device makes during encryption. Different operations produce slightly different sound patterns, which can be picked up by a sensitive microphone. In one study, researchers extracted 4096-bit RSA keys from a laptop using nothing more than a smartphone recording nearby [2]. The attacker just needs to be close enough to record. There’s no need to touch the device, modify it in any way, or send any data to it.

Vector Methods

- **Field recording:** A near-field recording uses a contact microphone or smartphone placed on or next to the device. A far-field recording uses a parabolic microphone from across a quiet room.
- **Laser vibrometry:** A laser pointed at a windowpane captures vibrations caused by sound from inside the room.
- **Differential analysis:** Hundreds of recordings are statistically compared to extract key bits even from noisy signals.

Mitigations

- Place cryptographic devices in soundproof enclosures or rooms with acoustic isolation, with white noise or ultrasonic jamming to mask acoustic emissions.
- Rotate keys frequently so that an extracted key expires quickly. This also limits the value of any other key extraction attack.
- Perform cryptography in a hardware security module designed to resist side-channel leakage. Implement constant-time cryptographic algorithms that execute the same operations regardless of input, eliminating the acoustic variation that differential analysis relies on.

Vector 2: Session Key Extraction from Flash Memory on LoRaWAN Sensors

LoRaWAN (**Long-Range Wide-Area-Network**) is a low-power radio protocol used for IoT sensors in cities, agriculture, and industrial monitoring. These sensors and devices communicate with temporary secret codes called session keys. These keys encrypt the sensor's data and verify that the data received came from that device, and are often stored long-term in plain, unprotected flash memory. With physical access to a sensor, an attacker can read those keys using debugging tools, allowing them to impersonate the device. From there, they can inject false readings or potentially knock other devices offline. This form of attack leaves no log entry. The network sees a legitimate device with valid keys. [3]

Vector Methods

- **Device impersonation and false data injection:** Using extracted keys, the attacker sends arbitrary sensor readings to obstruct data collection.
- **Replay attack:** Captured legitimate packets are retransmitted, which knocks frame counters out of sync and kicks devices offline.
- **Adaptive Data Rate (ADR) abuse:** Creates blind spots by forcing sensors to reduce transmission power.
- **Passive reconnaissance:** Before key extraction, an attacker maps network layout by capturing metadata such as signal strength and unencrypted device IDs.

Mitigations

- Generate ephemeral keys via **Over-the-Air Activation** instead of Activation-by-Personalization. Store keys in a **hardware security module**. Implement physical tamper detection erasing keys upon opening the enclosure. This can be as simple as a switch that triggers a power wipe.
- Upgrade to **LoRaWAN 1.1**, which separates the network and application session keys and introduces a dedicated join server for mutual authentication, directly closing the replay and key reuse paths described above.

Vector 3: *IoT Intrusion Detection Machine Learning Data Poisoning*

Traditional security systems rely on fixed rules that determine what triggers an alert, and what requires immediate action. Advancements in machine learning have accelerated a need for more adaptive defenses, which involves training a machine learning model on normal traffic and known attacks, (often benchmarked against datasets such as CICIDS2017), while able to spot anomalies alone. During this training phase, maliciously crafted samples could be injected into its dataset, teaching it to give false readings or ignore real attacks. A 2025 study found that deep learning models with adaptive filtering still missed between 3-5% of all malicious inputs [4]. This leaves even the more sophisticated defenses on the market with a deep imperfection.

Vector Methods

- **Label flipping:** Change labels in the training set from “malicious” to “benign.” This is the simplest method and only requires write access to the dataset.
- **Backdoor poisoning:** Insert samples with a hidden sequence of sensor alerts that acts as a deactivation trigger, causing normal behavior until the trigger blinds it.
- **Compromised data source:** If the system automatically collects training data from live sensors, one compromised sensor can feed poisoned data directly while appearing legitimate.

Mitigations

- Sanitize training data with outlier detection and statistical filters. Flag any sample that deviates significantly from expected distributions.
- Regularly retrain the model on a mix of new data and a set of clean, known, data. Check for performance drift. Use independently trained ensemble models for higher accuracy.
- Validate incoming sensor readings against physical plausibility before they reach the model. A temperature sensor reporting a 40°C swing in under a minute, for example, should be flagged and excluded from the training pipeline regardless of its credentials.

Conclusion: *Connecting Attack Vectors*

These three attack vectors form a connected attack chain. A LoRaWAN network server is the central piece of infrastructure that authenticates every sensor on the network, and it runs cryptographic operations continuously. That makes it a viable acoustic target. An attacker positioned near the server, in an adjacent room, a utility corridor, or anywhere with acoustic proximity, can record the server's high-frequency emissions during key processing and extracting the keys that govern the entire network. This gives them something more valuable than a single compromised sensor: the ability to impersonate any device on the network with valid credentials. The attacker no longer needs physical access to any field sensor. Using the extracted server keys, they inject false readings under legitimate device identities. The network sees valid credentials attached to every fabricated transmission, and no log entry is created. If the system automatically collects live sensor data to retrain its machine learning intrusion detection model, those injected readings enter the training pipeline as trusted input. Over time, the model learns that this behavior is normal. When the real intrusion happens, no alarm fires.

This combination of physical, network, and application-layer vectors could leave a single point-of-failure defense system without any way of fighting back, or any way of knowing how to. It comes down to knowing your tools. Knowing what they are supposed to do is important, but it is just as critical to understand what they could also end up being used for. A persistent attack may not be easy to stop, but mitigation efforts can make it harder to accomplish.

Sources

- [1] **Nawa (The Rope)**
Kobo Abe, 1954
 - [2] **RSA Key Extraction via Low-Bandwidth Acoustic Cryptanalysis**
D. Genkin, A. Shamir, and E. Tromer, in Advances in Cryptology, 2013
<https://eprint.iacr.org/2013/857>
 - [3] **Security Vulnerabilities in LoRaWAN**
X. Yang, E. Karampatzakis, C. Doerr, and F. Kuipers, IEEE IoTDI, 2018
<http://www.cyber-threat-intelligence.com/publications/IoTDI2018-LoraWAN.pdf>
 - [4] **Addressing Adversarial Attacks in IoT Using Deep-Learning AI Models**
S. R. Bommana, S. Veeramachaneni, S. E. Ahmed, and M. B. Srinivas,
IEEE Access, 2025 <https://ieeexplore.ieee.org/document/10930870>
-